

第 11 章

无线网络安全

自从意大利人马可尼在 1896 年申请了第一个无线电报专利以来,无线技术已经彻底地改变了人们接收信息的方式。从最早的收音机到现在的手机、无线网络设备,无线通信得到了长足发展,也催生了一系列的产品和服务。

无线技术与网络技术的融合提供了即时通信、永久在线的可能性,预示着另一场计算革命的到来,它的发展前景似乎是无限的。然而,作为一种新的技术,新的标准层出不穷,大家都想尽快出发,却没有把安全放在根本的位置上。无线通信与生俱来就会受到各种安全威胁:数据被窃听、被篡改、隐私被侵犯。如果安全威胁不能得到防御,无线网络的发展将受到阻碍。值得庆幸的是,这种需求正在得到重视,WTLS 和 802.1X 等标准正在逐步得到完善。

本章旨在对现在的无线网络安全技术做总结,主要介绍如下内容:

- 无线网络面临的安全威胁。
- 无线网络的安全协议分析。
- 无线网络安全解决方案。

无线网络是前沿技术,不幸的是,前沿意味着各种概念的夹杂,造成了混乱。现代媒体充斥着各种缩略语,如 CDMA, GSM, TDMA, 802.11, WAP, 3G, GPRS 和 Bluetooth 等。实际上无线网络技术分为无线蜂窝网络技术和无线数据网络技术两类。

11.1 无线网络面临的安全威胁

1. 窃听

无线网络易遭受匿名黑客的攻击,攻击者可以截获无线电信号并解析出数据。用于无线窃听的设备与用于无线网络接入的设备相同,这些设备经过很小的改动就可以被设置成截获特定无线信道或频率的数据的设备。这种攻击行为几乎不可能被检测到。通过使用天线,攻击者可以在距离目标很远的地方进行攻击。窃听主要用于收集目标网络的信息,包括谁在使用网络、能访问什么信息及网络设备的性能等。很多常用协议通过明文传送用户名和密码等敏感信息,使攻击者可以通过截获数据获得对网络资源的访问。即使通信被加密,攻击者仍可以收集加密信息用于以后的分析。很多加密算法(如微软的 NTLM)很容易被破解。如果攻击者可以连接到无线网络上,他还可以使用 ARP 欺骗进行主动窃听。ARP 欺骗实际上是一种作用在数据链路层的中间人攻击,攻击者通过给目标主机发送欺骗 ARP 数据包来旁路通信。当攻击者收到目标主机的数据后,再将它转

发给真正的目标主机。这样，攻击者可以窃听无线网络或有线网络中主机间的通信数据。

2. 通信阻断

有意或无意的干扰源可以阻断通信。对整个网络进行 DoS 攻击可以造成通信阻断，使包括客户端和基站在内的整个区域的通信线路堵塞，造成设备之间不能正常通信。针对无线网络的 DoS 攻击则很难预防。此外，大部分无线网络通信都采用公共频段，很容易受到来自其他设备的干扰。攻击者可以采用客户端阻断和基站阻断方式来阻断通信。攻击者可能通过客户端阻断占用或假冒被阻断的客户端，也可能只是对客户端发动 DoS 攻击；攻击者可能通过基站阻断假冒被阻断的基站。如前所述，有很多设备（如无绳电话、无线集群设备）都采用公共频段进行通信，它们都可以对无线网络形成干扰。所以，在部署无线网络前，电信运营商一定要进行站点调查，以验证现有设备不会对无线网络形成干扰。

3. 数据的注入和篡改

黑客通过向已有连接中注入数据来截获连接或发送恶意数据和命令。攻击者能够通过向基站插入数据或命令来篡改控制信息，造成用户连接中断。数据注入可被用做 DoS 攻击。攻击者可以向网络接入点发送大量连接请求包，使接入点用户连接数超标，以此造成接入点拒绝合法用户的访问。如果上层协议没有提供实时数据完整性检测，在连接中注入数据也是可能的。

4. 中间人攻击

中间人攻击与数据注入攻击类似，所不同的是它可以采取多种形式，主要是为了破坏会话的机密性和完整性。中间人攻击比大多数攻击更复杂，攻击者需要对网络有深入的了解。攻击者通常伪装成网络资源，当受害者开始建立连接时，攻击者会截取连接，并与目的端建立连接，同时将所有通信经攻击主机代理到目的端。这时，攻击者就可以注入数据、修改通信数据或进行窃听攻击。

5. 客户端伪装

通过对客户端的研究，攻击者可以模仿或克隆客户端的身份信息，以试图获得对网络或服务的访问。攻击者也可以通过窃取的访问设备来访问网络。要保证所有设备的物理安全非常困难，当攻击者通过窃取的设备发起攻击时，通过第 2 层访问控制手段来限制对资源的访问（如蜂窝网采用的通过电子序列码或 WLAN 采用的 MAC 地址验证等手段）都将失去作用。

6. 接入点伪装

高超的攻击者可以伪装接入点。客户端可能在未察觉的情况下连接到该接入点，并泄漏机密认证信息。这种攻击方式可以与上面描述的接入点通信阻断攻击方式结合起来使用。

7. 匿名攻击

攻击者可以隐藏在无线网络覆盖的任何角落，并保持匿名状态，这使定位和犯罪调

查变得异常困难。一种常见的匿名攻击称为沿街扫描（War Driving），指攻击者在特定的区域扫描并寻找开放的无线网络。这个名称来自一种古老的拨号攻击方式——沿街扫描，即通过拨打不同的电话号码来查找 Modem 或其他网络入口。值得注意的是，许多攻击者发动匿名攻击不是为了攻击无线网络本身，只是为了找到接入 Internet 并攻击其他机器的跳板。因此，随着匿名接入者的增多，针对 Internet 的攻击也会增加。

8. 客户端对客户端的攻击

在无线网络上，一个客户端可以对另一客户端进行攻击。没有部署个人防火墙或进行加固的客户端如果受到攻击，很可能会泄漏用户名和密码等机密信息。攻击者可以利用这些信息获得对其他网络资源的访问权限。在对等模式下，攻击者可以通过发送伪造路由协议报文以产生通路循环来实施拒绝服务攻击，或者通过发送伪造路由协议报文生成黑洞（吸收和扔掉数据报文）来实现各种形式的攻击。

9. 隐匿无线信道

网络的部署者在设计和评估网络时，需要考虑隐匿无线信道的问题。由于硬件无线接入点的价格逐渐降低，以及可以通过在装有无线网卡的机器上安装软件来实现无线接入点的功能，隐匿无线信道的问题日趋严重。网络管理员应该及时检查网络上存在的一些设置有问题或非法部署的无线网络设备。这些设备可以在有线网络上制造黑客入侵的后门，使攻击者可以在离网络很远的地点实施攻击。

10. 服务区标志符的安全问题

服务区标志符（SSID）是无线接入点用于标识本地无线子网的标志符。如果一个客户端不知道服务区标志符，接入点会拒绝该客户端对本地子网的访问。当客户端连接到接入点上时，服务区标志符的作用相当于一个简单的口令，起到一定的安全防护作用。如果接入点被设置成对 SSID 进行广播，那么所有的客户端都可以接收到它并用其访问无线网络。而且，很多接入点都采用出厂时默认设置的 SSID 值，黑客很容易通过 Internet 查到这些默认值。黑客获取这些 SSID 值后，就可以对网络实施攻击。因此，SSID 不能作为保障安全的主要手段。

11. 漫游造成的问题

无线网络与有线网络的主要区别在于无线终端的移动性。在 CDMA、GSM 和无线以太网中，漫游机制都是相似的。很多 TCP/IP 服务都要求客户端和服务器的 IP 地址保持不变，但是，当用户在网络中移动时，不可避免地会离开一个子网而加入另一个子网，这就要求无线网络提供漫游机制。移动 IP 的基本原理在于地点注册和报文转发，一个与地点无关的地址用于保持 TCP/IP 连接，而另一个随地点变化的临时地址用于访问本地网络资源。在移动 IP 系统中，当一个移动节点漫游到一个网络时，就会获得一个与地点有关的临时地址，并注册到外地代理上；外地代理会与所属地代理联系，通知所属地代理有关移动节点的接入情况。所属地代理将所有发往移动节点的数据包转发到外地代理上。这种机制会带来一些问题：首先，攻击者可以通过对注册过程的重放来获取发送到移动节点的数据；其次，攻击者也可以模拟移动节点以非法获取网络资源。

11.2 无线蜂窝网络的安全性

11.2.1 GSM 的安全性

1. GSM 网络体系结构

如图 11-1 所示, GSM 网络体系结构一共由 8 部分组成, 各部分的功能如下:

(1) 带有 SIM (Subscriber Identity Module) 卡的移动设备。SIM 卡是具有 32~64KB EEPROM 存储空间的微处理智能卡。SIM 卡上存储了各种机密信息, 包括持卡人的身份信息及加密和认证算法等。

(2) 基站收发信台 (BTS)。基站收发信台负责移动设备与无线网络之间的连接。每个蜂窝站点有一个基站收发信台。

(3) 基站控制器 (BSC)。基站控制器管理着多个基站收发信台。它的主要功能是频率分配和管理, 同时在移动用户从一个蜂窝站点移动到另一个蜂窝站点时处理交接工作。基站收发信台和基站控制器组成了基站子系统 (BSS)。

(4) 移动交换中心 (MSC)。移动交换中心管理着多个基站控制器, 同时它还提供到有线电信网络的连接。MSC 管理着移动用户与有线网络的通信, 同时它还负责不同 BSC 之间的交接工作。

(5) 认证中心 (AuC)。认证中心对 SIM 卡进行认证。

(6) 归属位置登记数据库 (HLR)。HLR 是在归属网络上用来存储和跟踪接入者信息的数据库, 保存了用户登记信息和移动设备信息, 如国际移动用户身份证明 (IMSI) 和移动用户 ISDN (MSISDN) 等。根据用户的数量, 一个单独的 GSM 运营商可能有多多个不同的 HLR。

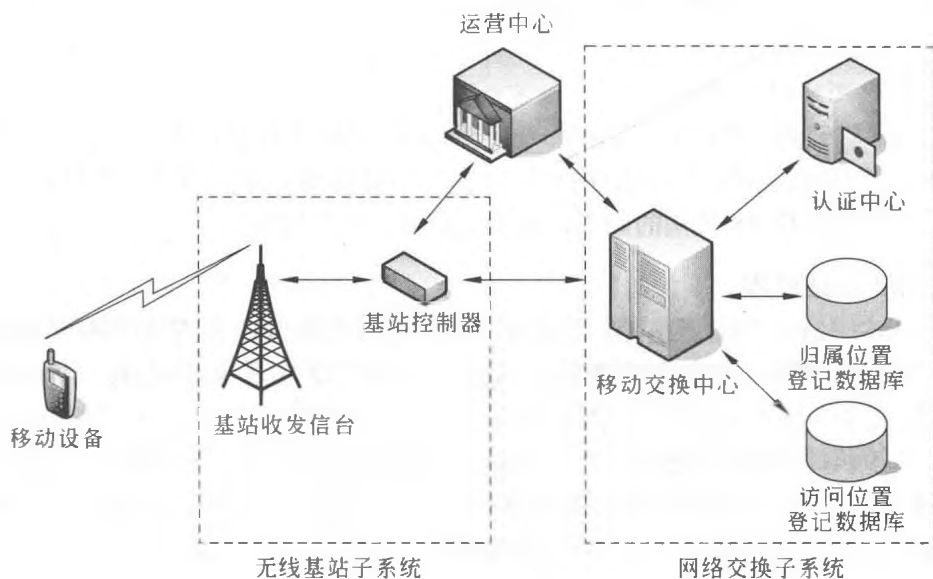


图 11-1 GSM 网络体系结构

(7) 访问位置登记数据库 (VLR)。VLR 是用于跟踪漫游到归属位置以外的用户信息的数据库, VLR 也会保存漫游用户的 IMSI 和 MSISDN 信息。当用户漫游时, VLR 会跟踪该用户并把电话转接到该用户的手机上。

(8) 运营中心 (OMC)。OMC 负责整个 GSM 网络的管理和性能维护。OMC 与 BSS 和 MSC 通信, 通常通过 X.25 网络连接。

2. GSM 的安全性

GSM 的安全基于对称密钥的加密体系。GSM 主要使用了 3 种加密算法:

(1) A3: 一种用于移动设备到 GSM 网络认证的算法。

(2) A5/1 或者 A5/2: 用于认证成功后加密语音和数据的分组加密算法。A5/1 主要用于西欧, A5/2 主要用于其他一些地区。

(3) A8: 一种用于产生对称密钥的密钥生成算法。

A3 和 A8 通常被称为 COMP128。

GSM 采用的加密算法由 GSM 成员国开发, 并没有经第三方检查或分析。由于 GSM 采取了一种机密的检查机制, 算法本身的强度引起了多方质疑。最早的安全架构创建于 20 世纪 90 年代, 那时, 64b 的密钥长度已足够。但是随着计算能力的提高, 64b 的密钥已经越来越无法抵御强力攻击。

GSM 安全架构中的第一步是认证: 确认一个用户和他的移动设备是经过授权而访问 GSM 网络的。因为 SIM 卡和移动网络具有相同的加密算法和对称密钥, 二者之间可以据此建立信任关系。在安全的移动设备中, 这些信息存储在 SIM 卡中。

SIM 中的信息由运营商定制, 包括加密算法、密钥、协议等, 通过零售商分发到用户手中。有两种 SIM 卡, 一种是只有 3KB 内存; 另一种有 8KB 内存, 可以存储短消息。

新购买的 SIM 卡中有如下信息:

(1) 移动用户身份标识 (IMSI), 相当于一串电子注册码。

(2) 单个用户认证密钥 (K_i), 128b 长。

(3) A3 和 A8 算法。

(4) 用户 PIN 码。

(5) PIN 解锁码 (PUK), 只有用户在忘记 PIN 码时才需要使用。

根据运营商提供的服务内容, 用户还可以在 SIM 卡里存储电话号码和短消息。MSC 也保存着 A3, A5 和 A8 算法的副本, 通常是存储在硬件设备里。

3. GSM 认证过程

由于 IMSI 是独一无二的, 攻击者能够用它来非法克隆 SIM 卡, 所以应尽量减少 IMSI 在电波中传播的次数。IMSI 仅在初次接入或 VLR 中的数据丢失时使用。在认证时, 采用临时用户身份标识 (TMSI) 来代替 IMSI。

当一个手机用户开始拨打电话时, GSM 网络的 VLR 会认证用户的身份。VLR 会立刻与 HLR 建立联系, HLR 从 AuC 获取用户信息。这些信息会转发到 VLR 上, GSM 认证与加密过程如图 11-2 所示, 下面的过程随之开始:

- (1) 基站产生一个 128b 的随机数或挑战值 (RAND)，并把它发给手机。
- (2) 手机使用 A3 算法和密钥 K_i 将 RAND 加密，产生一个 32b 的签名回应 (SRES)。
- (3) 同时，VLR 也计算出 SRES 值，因为 VLR 知晓 K_i 、RAND 和 A3。
- (4) 手机将 SRES 传输到基站，基站将其转发到 VLR。
- (5) VLR 将收到的 SRES 值与算出的 SRES 值对照。
- (6) 如果 SRES 值相符，认证成功，用户可以使用网络。
- (7) 如果 SRES 值不符，连接中止，错误信息报告到手机上。

这个简单过程有以下两点好处：

(1) K_i 始终保持在本地。认证密钥是整个认证过程中最重要的元素，确保认证密钥的安全尤为关键。在上面的认证模型当中， K_i 始终不通过空中传播，这样就不会被中途截取。 K_i 只保存在 SIM 卡、AuC、HLR 和 VLR 数据库中，SIM 卡也是防篡改的，网络管理员可以通过限制对这些数据库的访问使 K_i 被暴露的威胁最小化。

(2) 防强力攻击。一个 128b 的随机数意味着 3.4×10^{38} 种可能组合。即使一个黑客知道 A3 算法，猜出有效的 RAND/SRES 的可能性也非常小。

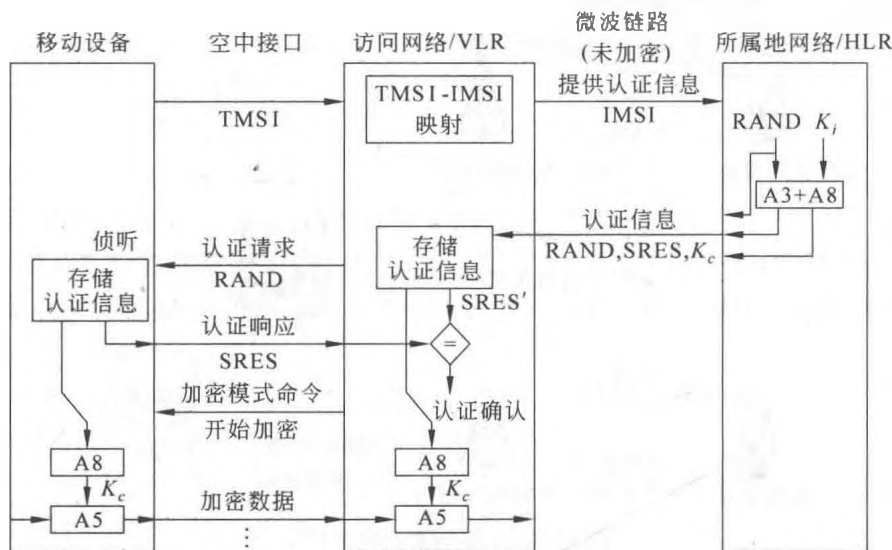


图 11-2 GSM 认证与加密过程

4. GSM 的保密性

在成功的认证后，GSM 网络和手机会完成加密信道的建立过程。首先需要产生一个加密密钥，然后该加密密钥被用来加密整个通信过程。加密连接建立的具体过程如下：

- (1) SIM 卡将 RAND 与 K_i 结合在一起，通过 A8 算法生成一个 64b 的会话密钥 K_c 。
- (2) GSM 网络也采用相同的 RAND 和 K_i 计算出相同的会话密钥 K_c 。
- (3) 通信双方采用 K_c 与 A5 算法，对手机与 GSM 网络之间的通信数据进行加密。

会话密钥也可重复使用，这样会提高网络的性能并减小因加密而产生的延迟。最后的步骤中包含用户的身份信息，这是实时记账所必需的。从上面的过程中可以看出，用户认证通过 K_i 和 IMSI 两个值来实现。因此，必须确保这两个值不被泄漏。

5. GSM 的安全缺陷

在 GSM 网络中，主叫用户和被叫用户通信时信号所经由的链路如图 11-3 所示。从图中可以看出，除无线链路被加密之外，基站到移动交换中心的微波连接和骨干网传输线路并未加密。归纳起来，GSM 的安全缺陷有以下几点。

(1) GSM 标准仅考虑了移动设备与基站之间的安全问题，而基站和基站之间没有设置任何加密措施，因此 K_c 和 SRES 在网络中以明文传输，给黑客窃听带来了便利。

(2) K_i 的长度是 48b，用户截取 RAND 和 SRES 后很容易破译 K_i ，而 K_i 一般固定不变，使 SIM 卡的复制成为可能。

(3) 单向身份认证，网络认证用户，但用户不认证网络，无法防止伪造基站和 HLR 的攻击。

(4) 缺乏数据完整性认证。

(5) 当用户从一个蜂窝小区进入另一个蜂窝小区进行漫游时，存在跨区切换。在跨区切换的过程中，有可能泄漏用户的秘密信息。

(6) 用户无法选择安全级别。

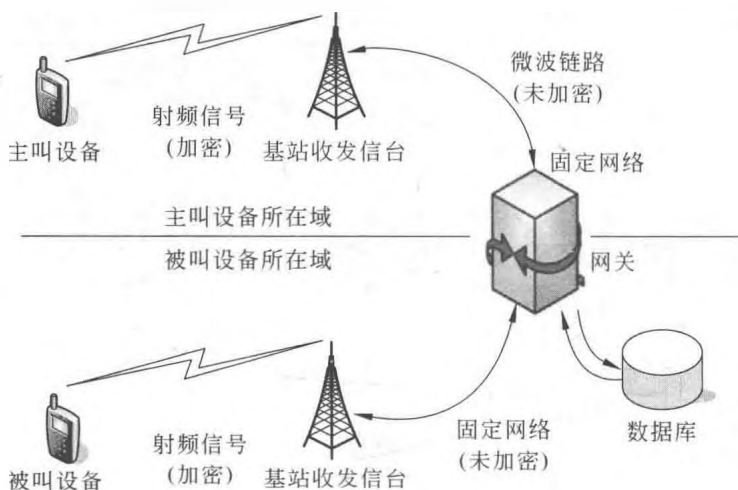


图 11-3 未经加密的内部链路

11.2.2 CDMA 的安全性

CDMA 网络的安全性同样也建立在对称密钥体系架构上。除了 CDMA 用防篡改的 UIM (User Identity Module) 卡代替了 GSM 的 SIM 卡外，其保密与认证架构大致与 GSM 相同。

CDMA 手机使用 64b 的对称密钥（称为 A-Key）来进行认证。在出售时，这个密钥被用程序输入到手机的 UIM 卡内，同时也由运营商保存。手机内的软件算出一个校验值，以确保 A-Key 被正确地输入到 UIM 卡中。

1. CDMA 认证

当用手机打电话时，CDMA 网络的 VLR 对用户进行认证。CDMA 网络使用一种称

为蜂窝认证和语音加密 (CAVE) 的算法。

为了最小化 A-Key 被截取的风险, CDMA 手机采用一种基于 A-Key 的动态生成数来进行认证。该值称为共享密钥 (SSD), CAVE 算法如图 11-4 所示, 由 3 个数值计算得出:

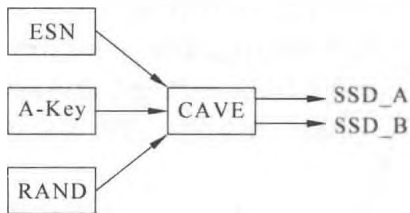


图 11-4 CAVE 算法

- (1) 用户的 A-Key。
- (2) 手机的电子序列号 (ESN)。
- (3) 一个随机数 RAND。

这 3 个数值通过 CAVE 算法产生两个 64b 杂凑值 SSD_A 和 SSD_B。SSD_A 用于认证, 而 SSD_B 用于加密。SSD_A 等同于 GSM 的 SRES, SSD_B 等同于 GSM 的 K_c 。

当移动用户处于漫游状态时, SSD_A 和 SSD_B 以明文方式从用户的归属网络传输到当前的访问网络中。这会造成安全威胁, 因为黑客可以通过截获 SSD 值来克隆手机。为了预防这种攻击, 手机和网络使用一个同步的通话计数器。每当手机和网络建立新的通话时, 计数器就会更新。这样就能够检测到计数器没有更新的克隆 SSD。

CDMA 的认证同样建立在挑战/响应机制上。认证可以由本地 MSC 或者 AuC 来完成。如果一个 MSC 不能完成 CAVE 的计算, 认证就由 AuC 来实现。如图 11-5 所示, 下面是 CDMA 的认证步骤:

- (1) 移动手机拨出电话。
- (2) MSC 从归属网络位置寄存器 (HLR) 获取用户信息。
- (3) MSC 产生一个 24b 的随机数用于挑战值 (RANDU)。
- (4) RANDU 被传输到手机。
- (5) 手机收到 RANDU, 把它和 SSD_A、ESN 和 MIN 一起用 CAVE 生成杂凑值, 得到 18b 的 AUTHU。
- (6) 同时, MSC 通过 SSD_A、ESN 和 MIN、CAVE 计算出自己的 AUTHU。
- (7) 手机将 AUTHU 传输到 MSC。
- (8) MSC 将自己计算出的 AUTHU 与接收到的 AUTHU 比较, 如果 AUTHU 匹配, 通话继续进行, 如果 AUTHU 不匹配, 通话中止。

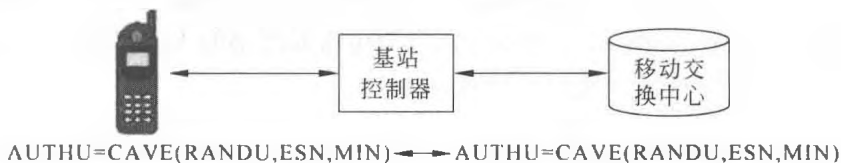


图 11-5 CDMA 认证

2. CDMA 的保密性

CDMA 采用与 GSM 类似的语音加密机制。在进行认证的同时, CDMA 手机也完成了以下工作:

- (1) 移动手机收到 RAND, 将它与 SSD_B、ESN 和 MIN 一起用 CAVE 生成杂凑值, 得到 18b 的语音隐私掩码 (Voice Privacy Mask, VPMASK)。

(2) 同时, MSC 通过 SSD_B、ESN、MIN 和 CAVE 算出自己的 VPMASK。

(3) VPMASK 用于手机与 CDMA 网络之间的语音与数据加密。

一个类似的过程也被用于生成 64b 的数据加密密钥, 称为信令消息加密密钥 (Signaling Message Encryption Key, SMEKEY)。

虽然 CDMA 标准允许语音通信加密, 但是 CDMA 运营商并不总是提供这种服务, 因为 CDMA 采用的扩频技术和随机编码技术本身就比较 GSM 采用的 TDMA 技术更难破解。

与 GSM 一样, CDMA 采用的加密算法也是保密的, 因此针对 CAVE 算法的攻击很少, 但是这并不意味着 CAVE 算法本身就是安全的, 在理论上它很可能也存在着漏洞。幸运的是, CDMA 也开始逐渐采用公钥密码体制, 这样会大大提高系统的安全性, 同时也使 CDMA 运营商能够提供更多的移动商务服务。

11.2.3 3G 系统的安全性

1. 用户身份保密

为了达到用户身份保密要求, 3G 系统使用了两种机制来识别用户身份: 一种是使用临时用户身份标识 (TMSI); 另一种是使用加密的永久用户身份标识 (IMSI)。3G 系统也要求用户不能长期使用同一身份。另外, 3G 系统还对接入链路上可能泄漏用户身份的信令信息及用户数据进行加密传送。为了保持与第二代系统的兼容, 3G 系统也允许使用非加密的 IMSI。

TMSI 具有本地特征, 仅在用户登记的位置区域和路由区域内有效。在此区域外, 为了避免混淆, 附加一个位置区域标识 LAI 或路由区域标识 RAI。TMSI 与 IMSI 之间的关系被保存在用户注册的访问位置寄存器 VLR/SGSN 中。TMSI 的分配在系统初始化后进行, 如图 11-6 所示。

VLR 产生新的身份 TMSI, 并在其数据库中存储 TMSI 和 IMSI 的关系。TMSI 应该是不可预测的。然后 VLR 发送 TMSI 和新的位置区域身份 LAI 给用户。一旦收到, 用户存储 TMSI 并自动地删除与以前所分配的 TMSI 的关系。用户发送确认信息至 VLR; 一旦收到确认, VLR 即从其数据库中删除旧的临时身份 TMSI 和 IMSI 的关系。

当用户第一次在服务网注册时, 或者当服务网不能从 TMSI 重新获得 IMSI 时, 系统将采用永久身份机制, 如图 11-7 所示。该机制由访问网络的 VLR 发起, 请求用户发送它的永久身份, 用户的响应中包含明文的 IMSI。

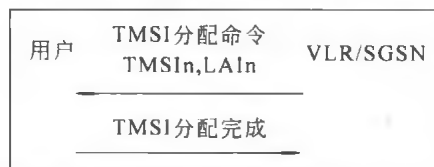


图 11-6 TMSI 的分配



图 11-7 永久身份机制

2. 认证与密钥协商

3G 系统沿用了 GSM 的认证方法, 并对其做了改进。WCDMA 系统使用 5 参数的认

证向量 $AV = RAND \parallel XRES \parallel CK \parallel IK \parallel AUTN$ 进行双向认证。3G 系统认证执行 AKA 认证密钥协商协议, 认证过程如图 11-8 所示, 具体步骤如下:

- (1) $MS \rightarrow VLR$: IMSI, HLR。
- (2) $VLR \rightarrow HLR$: IMSI。
- (3) $HLR \rightarrow VLR$: $AV = RAND \parallel XRES \parallel CK \parallel IK \parallel AUTN$ 。
- (4) $VLR \rightarrow MS$: $RAND \parallel AUTN$ 。
- (5) $MS \rightarrow VLR$: RES。

VLR 收到移动用户 MS 的注册请求后, 向 HLR 发送该用户的 IMSI, 请求对该用户进行认证。HLR 收到 VLR 的认证请求后, 生成序列号 SQN 和随机数 RAND, 计算认证向量 AV 并发送给 VLR。VLR 接收到认证向量后, 将 RAND 及 AUTN 发送给 MS, 请求用户产生认证数据。MS 接收到认证请求后, 计算 XMAC, 并与 AUTN 中的 MAC 比较, 若不同, 则向 VLR 发送拒绝认证消息, 并放弃该过程。同时, MS 验证接收到的 SQN 是否在有效的范围内, 若不在有效的范围内, MS 则向 VLR 发送“同步失败”消息, 并放弃该过程。上述两项验证通过后, MS 计算认证响应 RES、加密密钥 CK 和完整性密钥 IK, 并将 RES 发送给 VLR。VLR 接收到来自 MS 的 RES 后, 将 RES 与认证向量 AV 中的 XRES 进行比较, 相同则认证成功, 否则认证失败。该认证过程达到了如下安全目标: ①实现了用户与网络之间的相互认证; ②建立了用户与网络之间的会话密钥; ③保持了密钥的新鲜性。

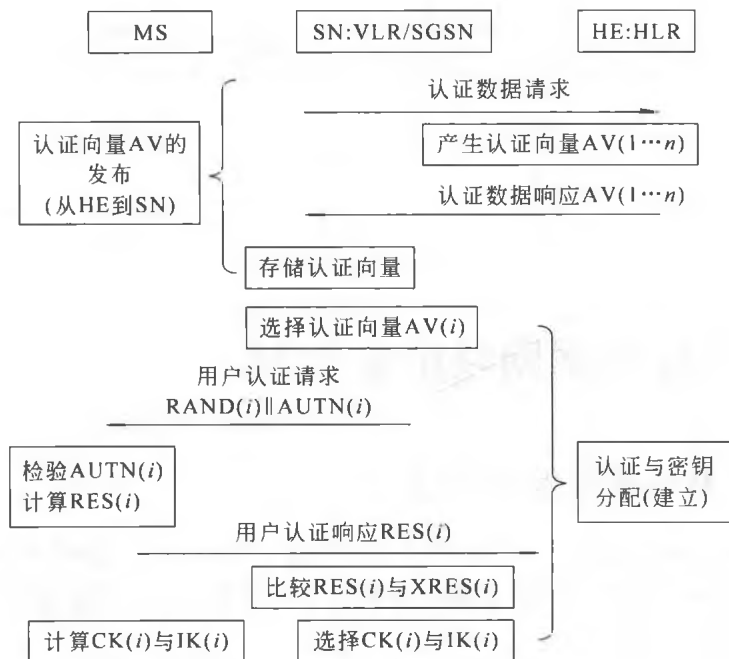


图 11-8 认证与密钥协商过程

3. 接入链路数据保护

在移动用户 MS 与网络之间的安全通信模式建立之后, 所有发送的消息采用两种安全机制加以保护: ①数据完整性机制; ②数据加密机制。

数据完整性保护如图 11-9 所示。 f_9 为完整性保护算法； I_k 为完整性密钥，长为 128b；COUNT-I 为完整性序列号，长为 32b；FRESH 为网络方产生的随机数，长为 32b，用于防止重放攻击；MESSAGE 为发送的消息；DIRECTION 为方向位，长为 1b；MAC-I 为用于消息完整性保护的消息认证码。接收方计算 XMAC-I，并与接收到的 MAC-I 比较，以此验证消息的完整性。

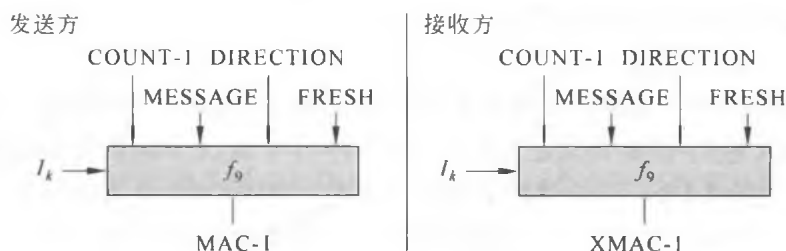


图 11-9 消息认证码的产生

数据加/解密如图 11-10 所示。其中， f_8 为加密算法； C_k 为加密密钥，长为 128b；COUNT-C 为加密序列号，长为 32b；BEARER 为负载标识，长为 5b；DIRECTION 为方向位，长为 1b；LENGTH 为所需的密钥流长度，长为 16b。

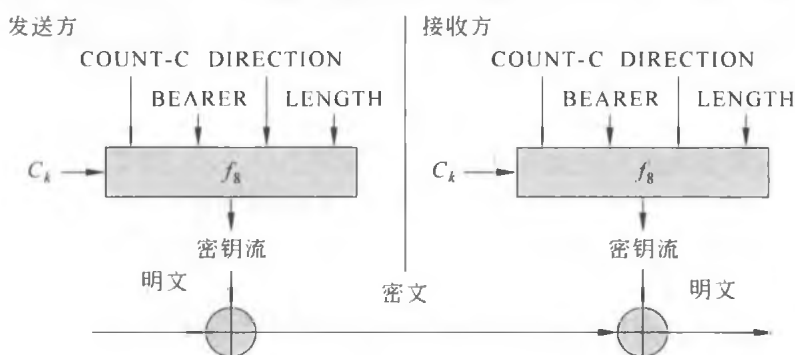


图 11-10 数据加/解密

11.3 无线数据网络的安全性

11.3.1 有线等效保密协议

IEEE 802.11b 标准定义了一个加密协议：WEP（Wired Equivalent Privacy，有线等效保密协议），用来对无线局域网中的数据流提供安全保护。该协议采用 RC4 流加密算法，能提供的功能主要包括：

- (1) 访问控制——防止没有 WEP 密钥的非法用户访问网络。
- (2) 保护隐私——通过加密手段保护无线局域网上传输的数据。

1. WEP 加密过程

WEP 加密过程如图 11-11 所示。从图中可以看出，在对明文数据的处理上采用了两

种运算：一是对明文进行的流加密运算（即异或运算）；二是为防止数据被非法篡改而进行的数据完整性检查向量（ICV）运算。

(1) 40b 的加密密钥与 24b 的初始向量（IV）结合在一起，形成 64b 长度的密钥。

(2) 生成的 64b 密钥被输入到伪随机数生成器（PRNG）中。

(3) 伪随机数生成器输出一个伪随机密钥序列。

(4) 生成的序列与数据进行位异或运算，形成密文。

为了保证数据不被非法篡改，一种完整性算法（CRC32）会应用在明文上，生成 32b 的 ICV。明文与 32b 的 ICV 合并后被加密，密文与 IV 一起被传输到目的地。

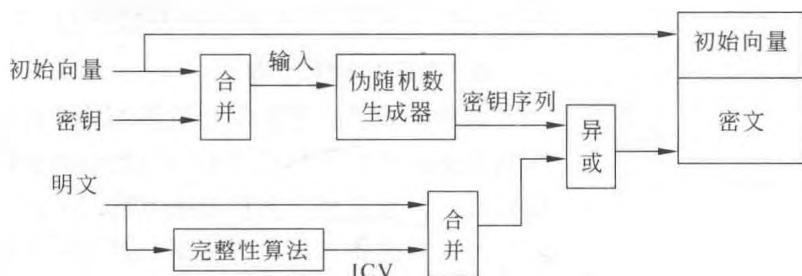


图 11-11 WEP 加密过程

2. WEP 解密过程

WEP 解密过程如图 11-12 所示。为了对数据流进行解密，WEP 进行如下操作：

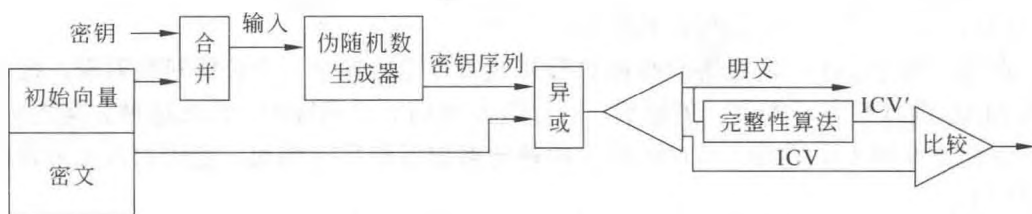


图 11-12 WEP 解密过程

(1) 接收到的 IV 被用来产生密钥序列。

(2) 加密数据与密钥序列一道产生解密数据和 ICV。

(3) 解密数据通过数据完整性算法生成 ICV。

(4) 将生成的 ICV 与接收到的 ICV 进行比较。如果不一致，将错误信息报告给发送方。

3. WEP 认证方法

一个客户端如果没有被认证，将无法接入无线局域网。因此必须在客户端设置认证方式，而且该方式应与接入点采用的方式兼容。IEEE 802.11b 标准定义了两种认证方式：开放系统和共享密钥认证。

(1) 开放系统认证。

开放系统认证是 IEEE 802.11 协议采用的默认认证方式。开放系统认证对请求认证的任何人提供认证。整个认证过程通过明文传输完成，即使某个客户端无法提供正确的

WEP 密钥，也能与接入点建立联系。

(2) 共享密钥认证。

共享密钥认证采用标准的挑战/响应机制，以共享密钥来对客户端进行认证。该认证方式允许移动客户端使用一个共享密钥来加密数据。WEP 允许管理员定义共享密钥。没有此共享密钥的用户将被拒绝访问。用于加密和解密的密钥也被用于提供认证服务，但这会带来安全隐患。与开放系统认证相比，共享密钥认证方式能够提供更好的认证服务。如果一个客户端采用这种认证方式，客户端必须支持 WEP。WEP 认证过程如图 11-13 所示。

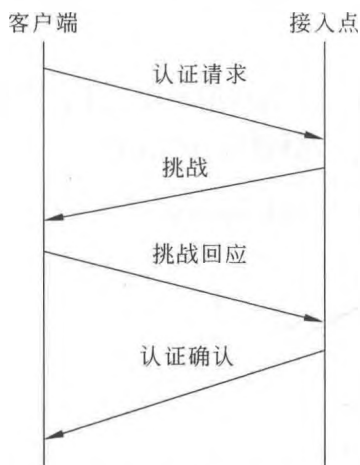


图 11-13 WEP 认证过程

4. WEP 密钥管理

共享密钥被存储在每个设备的管理信息数据库中。虽然 IEEE 802.11 标准没有指出如何将密钥分发到各个设备上，但它提到了两种解决方案：

- (1) 各设备和接入点共享一组共 4 个默认密钥。
- (2) 每个设备与其他设备建立密钥对关系。

第一种方案提供了 4 个密钥。如果一个客户端获得了这些默认密钥，该客户端就可以与整个子系统的所有设备进行通信。客户端或接入点可以采用这 4 个密钥中的任意一个来实施加密和解密运算。这种方案的缺点是：如果默认密钥被广泛分发，它们就可能被泄漏。

在第二种方案中，每个客户端都要与其他所有设备建立一个密钥对映射表，每个不同的 MAC 地址都有一个不同的密钥，且知道此密钥的设备较少，因此这种方案更安全。虽然这种方案减小了受攻击的可能性，但是随着设备数量的增加，密钥的人工分发会变得很困难。

11.3.2 802.1x 协议介绍

802.1x 协议最早作为有线以太网络的标准提出，它也同样适用于无线局域网，为认证和密钥分发提供了一个整体框架。它利用了很多拨号网络的安全机制，为每个用户和每个网络会话提供了独一无二的加密密钥，同时支持 128b 的密钥长度。它还包含一个密钥管理协议，能够提供密钥自动生成功能。密钥也可以在设定的时段后自动改变。802.1x 也支持 RADIUS 和 Kerberos 服务，通过与上层认证协议一起使用，可提供认证和密钥生成功能。

在 802.1x 网络中有如下 3 种角色：

- (1) 认证者：在 802.11 网络中，通常是接入点。它确保认证的进行，同时将数据路由至网络中正确的接收者。
- (2) 认证请求端：在 802.11 网络中，通常是客户端设备提出认证请求。
- (3) 认证服务器 (AS)：可信的第三方，为客户端提供实际的认证服务，通常为 Radius 认证服务器。

802.1x 的操作可以通过受控端口和非受控端口的概念来说明。受控端口和非受控端口是同一物理端口的逻辑划分。一个数据帧能否通过接入点路由到受控端口或非受控端口，取决于客户端的认证状态。如图 11-14 所示，在客户端通过认证服务器认证前，接入点只允许客户端与认证服务器通信，只有在被认证服务器认证后，客户端才能与网络上的其他设备通信。

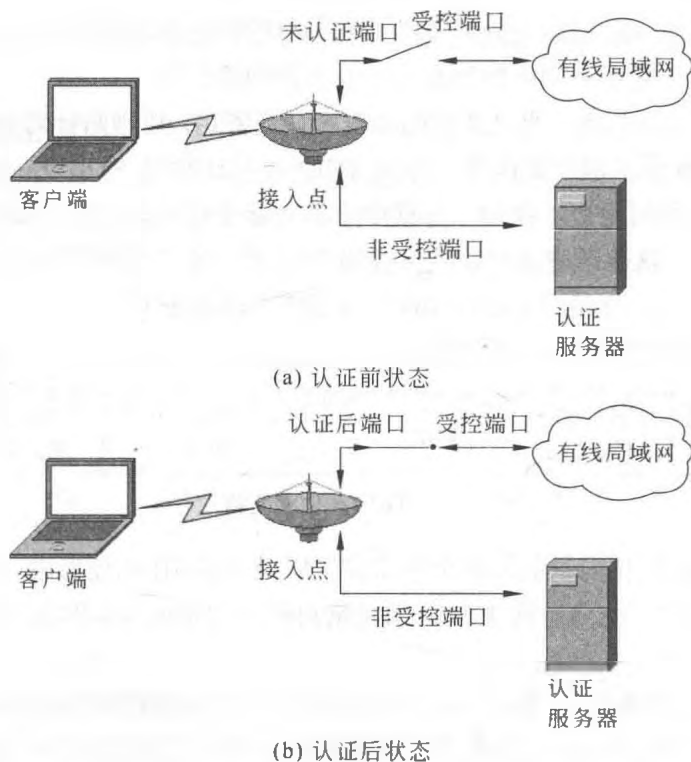


图 11-14 认证前状态与认证后状态

实际的认证数据交互过程由上层的认证协议实现，认证的协议和数据的转发由 802.1x 协议控制。值得注意的是，认证是客户端与服务器的双向认证。在完成认证的同时，会生成物理介质访问控制层（MAC）的加密密钥。802.1x 会使用该密钥在接入点和客户端之间进行加密。在 802.1x 网络中会生成两种密钥，一种是会话密钥（也称为双方使用的密钥）；另一种是群密钥（也称为群内使用密钥）。群密钥由所有接到同一接入点的客户端共享，主要用于多播。而会话密钥则随着客户端和接入点的连接变化而变化，这样，在客户端与接入点之间就形成了专用信道。

11.3.3 802.11i 标准介绍

802.11i 标准针对 WEP 的诸多缺陷加以改进，增强了无线局域网中的数据加密和认证性能。802.11i 规定使用 802.1x 的认证和密钥管理方式。在数据加密方面，802.11i 定义了临时密钥完整性协议（TKIP）、密文分组链接模式——消息认证码协议（CCMP）两种加密模式。其中，TKIP 是 WEP 机制的加强版，它采用 RC4 作为核心加密算法，可以

从 WEP 上平滑升级，而 CCMP 采用 AES 分组加密算法和 MAC 消息认证协议，使无线局域网的安全性大幅提高，但是由于与现有无线网络不兼容，升级费用很高。

1. TKIP 加密模式

与 WEP 相比，TKIP 在以下 4 个方面得到了加强：

- (1) 使用 Michael 消息认证码以抵御消息伪造攻击。
- (2) 使用扩展的 48b 初始化向量 (IV) 和 IV 顺序规则以抵御消息重放攻击。
- (3) 对各数据包采用不同密钥加密以弥补密钥的脆弱性。
- (4) 使用密钥更新机制，提供新鲜的加密和认证密钥，以预防针对密钥重用的攻击。

TKIP 采用 48b 的扩展初始向量，称为 TKIP 序列计数器 (TSC)。使用 48b 的 TSC 延长了临时密钥的使用寿命，在同一会话中不必重新生成临时密钥。由于每发送一个数据报，TSC 就更新一次临时密钥可以连续使用 2^{48} 次而不会产生密钥重用的问题，在一个稳定而高速的连接中，这相当于要过 100 年才会产生重复密钥。

TKIP 加密报文格式如图 11-15 所示。



图 11-15 TKIP 加密报文格式

TSC 由 WEP 初始化向量的前两个字节和扩展向量的 4B 构建而成。TKIP 将 WEP 加密数据报的长度扩展了 12B，这 12B 分别是来自扩展向量的 4B 和来自消息完整性代码 MIC 的 8B。

TKIP 的封装过程如图 11-16 所示。封装过程采用临时密钥和消息认证码密钥，这些密钥由 802.1x 中产生的会话密钥生成。临时密钥、传输方地址和 TSC 被用于第一阶段的密钥混淆过程，生成每个数据报所用的加密密钥。该密钥的长度为 128b，被分成一个 104b 的 RC4 加密密钥和一个 24b 的初始向量。

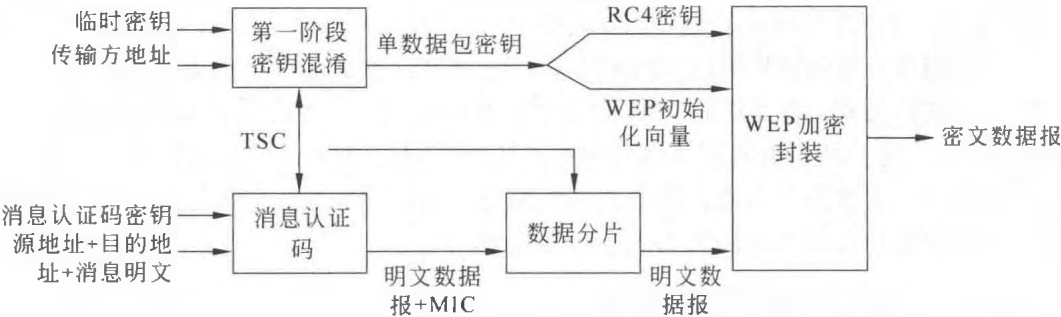


图 11-16 TKIP 的封装过程

消息认证码使用数据报的明文及源、目的 MAC 地址生成，这样，数据报的信息随着源和目的 MAC 地址的改变而改变，可防止数据报的伪造。

消息认证码使用称为 Michael 的单向杂凑函数生成，而非采用 WEP 生成数据完整性

检查向量 (ICV) 时所使用的简单的 CRC-32 函数, 这使黑客截取和篡改数据报的难度加大。如果需要, 数据报可以分片, 在每个分片数据报输入 WEP 加密引擎之前, TSC 都会加 1。

解密过程和加密过程类似。在从收到的数据报中提取 TSC 后, 接收方会对其进行检查, 确保它比先前收到的数据报的 TSC 大, 以防止重放攻击。在接收到并解密数据报生成消息完整性代码 (MIC) 后, 接收方将其与收到的 MIC 进行比较, 以确保数据报没有被篡改。

2. CCMP 加密模式

CCMP 提供比 TKIP 更强的加密模式, 也是 802.11i 规定强制采用的加密模式。它采用 128b 的分组加密算法 AES。AES 可以采用多种模式, 而 802.11i 采用计数器模式和密文分组链接-消息认证码模式。计数器模式保证了数据的私密性, 而密文分组链接-消息认证码模式保证了数据的完整性和认证性。

图 11-17 为 CCMP 加密数据报格式。该数据报比原始数据报延长了 16B, 除了没有 WEP 的完整性检查向量 (ICV) 以外, 它的格式与 TKIP 的数据报格式相同。

初始向量 4B	扩展向量 4B	数据	消息完整性代码 8B
------------	------------	----	---------------

图 11-17 CCMP 加密报文格式

与 TKIP 相同, CCMP 也采用 48b 的初始化向量, 称为数据报数 (PN)。数据报数和其他信息一起用于初始化 AES 加密算法, 并用于消息验证码的计算和数据的加密。

图 11-18 显示了 CCMP 封装过程。在消息验证码的计算和数据报的加密中, AES 采用了相同的临时加密密钥。与 TKIP 一样, 临时密钥也是由 802.1x 交换产生的主密钥生成的。

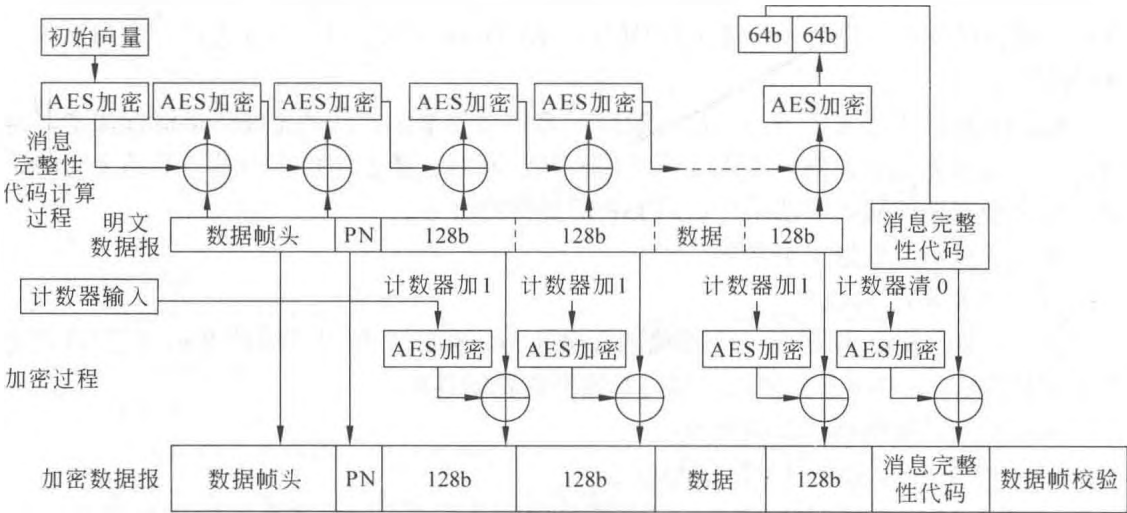


图 11-18 CCMP 封装过程

MIC 的计算与数据报的加密同步进行。在 MIC 的计算中使用了初始化向量 (IV)，该向量由一个标志值、PN 和数据帧头的某些部分组成。IV 在注入一个 AES 分组后的输出与数据帧头的某些部分异或后再次注入另一个 AES 分组，这个过程重复下去生成一个 128b 的 CBC-MAC 值。该值的前 64b 被取出并附加到密文数据报后面。

计数器输入也由 PN、一个标志值、数据帧头的某些部分和一个初始化为 1 的计数器组成。计数器输入被注入一个 AES 分组加密盒，输出与 128b 的明文异或，计数器加 1 后这个过程继续进行，直到整个数据帧被加密。最后计数器被置为 0，输入到一个 AES 分组加密盒，输出与 MIC 异或后添加到加密数据报的后面。最后，将全部加密数据报进行传输。

CCMP 的解密过程基本上是上述过程的逆过程。最后一步是将计算得到的 MIC 值与收到的 MIC 值进行对比，以证明数据没有被篡改。

3. 上层认证协议

802.11i 标准并没有规定上层采用的认证协议，因为这些协议作用在 3 层以上，不在 802.11 规定的范围内。上层认证协议主要应用于企业网络，提供客户端和服务器的相互认证功能，并生成会话密钥用于数据加密。上层认证协议与 802.1x 配合使用，802.1x 主要用于确保上层认证协议的使用及正确地转发消息，而上层认证协议则提供实际的认证功能。很多企业会采用 Radius 服务器提供认证功能。最流行的认证协议包括：具有传输层安全的可扩展认证协议 (EAP-TLS)、受保护的可扩展认证协议 (PEAP)、具有传输层隧道的可扩展认证协议 (EAP-TTLS) 和轻量可扩展认证协议 (LEAP)。

上面介绍的 802.11i 的各个组成部分应当作为一个整体来部署，任何部分独立使用时都存在着自己的安全缺陷。

11.3.4 802.16 标准的安全性

IEEE 802.16 标准又称为 WiMAX (Worldwide Interoperability for Microwave Access)，是一种为企业和家庭用户提供“最后一千米接入”的宽带无线连接方案。802.16 不仅是无线城域网的标准，同时也继 TD-SCDMA、WCDMA 和 CDMA2000 之后，成为第 4 个 3G 标准。

802.16 标准中定义了安全子层，通过对客户端与基站之间的无线信道进行加密，为客户端在访问无线城域网时提供数据的保密性。同时，通过增加客户端与基站之间的认证，安全子层也能防止非法用户访问 ISP 所提供的服务。

安全子层中又包括 5 个部分：

(1) 安全关联 (SA)

安全关联 (SA) 维护着一个连接的安全状态。802.16 使用了两种 SA，但只特别定义了数据 SA，主要用于保护客户端与基站间的传输连接。

数据安全关联包括下面的内容：

- 一个 16b 的 SA 标识符 (SAID)。
- 用于加密数据的加密算法，该标准采用的是密文分组链接模式的 DES 算法。
- 两个用于加密数据的密钥 (TEK)，一个是当前使用的密钥；另一个是当前密钥

过期后将使用的密钥。

- 两个 2b 的密钥标识符。
- TEK 的生命周期。默认为半天，最短为 30 分钟，最长为 7 天。
- 每个 TEK 的初始向量。
- SA 的类型定义。主 SA 是在链路初始化时建立的；静态 SA 是在基站上设定的；动态 SA 是在生成动态传输连接时生成的。

为保证传输连接的安全性，客户端会使用 `create_connection` 请求创建一个初始 SA 数据。为支持多播，标准允许多个连接 ID 共享同一个 SA。在网络连接时，802.16 会给辅助管理信道自动创建一个 SA，因此一个客户端通常有两个或 3 个 SA，一个用于辅助管理信道，另一个同时（或两个分别）用于上连和下连传输连接。每个多播组共享一个 SA。

虽然 IEEE 802.16 标准中没有明确指出 SA 的具体格式，但是它应包括以下内容：

- 一个用于验证客户端的 X.509 证书。
- 一个 160b 的授权密钥 (AK)。客户端正确使用此密钥意味着已被授权使用该连接。
- 一个 4b 的授权密钥标志符。
- 一个 AK 生命周期值。范围为 1~70 天，默认为 7 天。
- 一个用于密钥分配的密钥加密密钥 KEK (一个 112b 的 3DES 密钥)， $KEK = \text{Truncate-128}(\text{SHA-1}((AK \parallel 0^{44}) \oplus 53^{64}))$ ，其中， $\text{Truncate-128}(X)$ 表示只取 X 的前 128b， $a \parallel b$ 意味着将 a 字符串和 b 字符串合并， $\oplus$ 表示异或， a^n 表示将数字 a 重复 n 次，SHA-1 为标准杂凑算法。
- 一个基站用于向客户端认证密钥分发信息的下连 HMAC (基于杂凑函数的消息认证码) 密钥，密钥由公式 $\text{HMAC key} = \text{SHA-1}((AK \parallel 0^{44}) \oplus 3A^{64})$ 生成。
- 一个客户端用于向基站认证密钥分发信息的上连 HMAC (基于杂凑函数的消息认证码) 密钥，密钥由公式 $\text{HMAC key} = \text{SHA-1}((AK \parallel 0^{44}) \oplus 5C^{64})$ 生成。
- 一个已授权数据 SA 列表。

一个授权 SA 由一个特定客户端和一个特定基站所共享。标准中建议将 AK 作为基站和客户端的共享密钥，基站使用授权 SA 来配置客户端的数据 SA。

(2) X.509 证书应包括的内容

X.509 证书用于证明通信双方的身份。标准中定义了 X.509 证书应包括下述内容：

- X.509 证书格式第 3 版。
- 证书序列号。
- 证书颁布者采用的签名算法——公钥签名标准 1，即 RSA 加密加上 SHA-1 杂凑。
- 证书颁布者。
- 证书有效期。
- 证书所有者的公钥，包括公钥的适用范围，仅用于 RSA 加密。
- 签名算法，与证书颁布者采用的签名算法类似。
- 证书颁布者的签名，采用 ASN.1.DER 编码标准产生的签名。

标准中没有定义 X.509 证书的扩展内容和基站证书，但是它定义了两种证书类型：

制造商证书和客户端证书。制造商证书用于标识 802.16 设备的制造者，它可以是自签名证书或由第三方颁发的证书。客户端证书标识一个特定的客户端，并将其 MAC 地址包含在证书所有者字段内。

客户端证书通常由制造商产生。基站使用制造商的公钥来验证客户端证书，从而验证设备身份的真实性。这种设计要求客户端必须妥善保管自己的私钥，以防泄漏。

（3）PKM 授权协议

PKM 授权协议将授权令牌分发给一个被授权的客户端。该授权协议涉及一个客户端与基站的三步交互过程：

- ① 客户端发送生产者证书到基站。
- ② 客户端发送客户端证书、客户端支持的加密、认证算法和 SA 标识符给基站。
- ③ 基站返回使用客户端公钥和 RSA 加密算法加密的授权密钥（AK）、密钥生命周期、序列号和 SA 标识符列表。

授权密钥的正确使用意味着客户端已被授权访问无线城域网络，标准中规定 AK 只在客户端与基站间共享，而不能泄漏给第三方。

（4）机密性和密钥管理

PKM 协议通过在基站与客户端之间进行两到三步信息交互以建立 SA。第一步是可选项，由基站提出重新生成密钥的请求。具体交互过程如下：

- ① 基站发送序列号、SA 标识符及使用 HMAC 算法和下连密钥生成的序列号与 SA 标识符的杂凑值。
- ② 客户端发送序列号、SA 标识符及使用 HMAC 算法和上连密钥生成的序列号与 SA 标识符的杂凑值。
- ③ 基站发送序列号、SA 标识符、当前正在使用的数据加密密钥、即将采用的新数据加密密钥，以及使用 HMAC 算法和下连密钥对上述字段生成的杂凑值。

（5）数据加密

802.16 数据加密封装如图 11-19 所示，DES-CBC 加密只对封装数据进行加密，对帧头和 CRC 则不做处理。数据帧头包括一个两位的字段用于标识所用的数据加密密钥，它并不包含 CBC 加密模式所用的初始化向量。为了计算该初始化向量，802.16 标准将最新

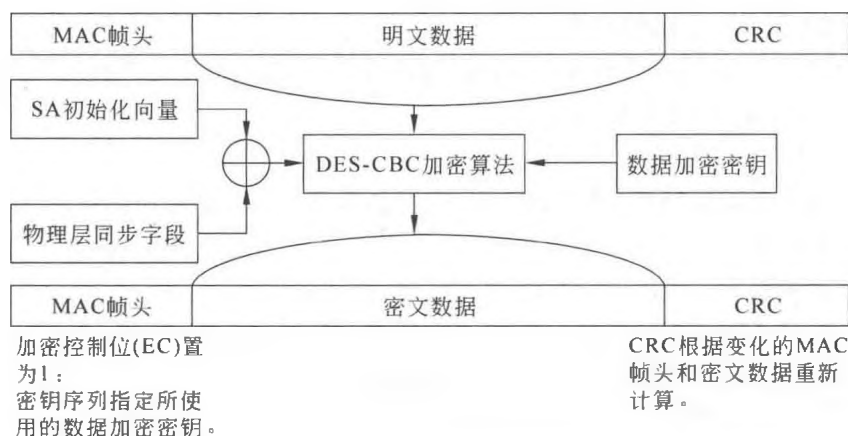


图 11-19 802.16 数据加密封装

数据帧中的物理层同步字段与 SA 初始化向量进行异或运算生成该向量。由于 SA 初始化向量是恒定不变和公开的，而物理层同步字段又是重复和可预测的，因此数据加密采用的初始化向量也是可预测的。

11.3.5 WAPI 标准简介

WAPI (WLAN Authentication and Privacy Infrastructure) 是我国自主研发、拥有自主知识产权的无线局域网安全技术标准，由 ISO/IEC 授权的 IEEE Registration Authority 审查并获得认可。WAPI 与现行的 802.11b 传输协议比较相近，区别是所采用的安全加密技术不同：WAPI 采用一种名为“无线局域网认证与保密基础架构 (WAPI)”的安全协议，而 802.11b 则采用 WEP。

WAPI 安全机制由 WAI 和 WPI 两部分组成，WAI 和 WPI 分别实现用户身份认证和传输数据加密功能。整个系统由接入点 (AP)、站 (点) (STA) 和认证服务单元 (ASU) 组成。

(1) 接入点 (Access Point, AP)：任何一个具备站点功能、可通过无线媒体为关联的站点提供访问服务能力的实体。

(2) 站 (点) (Station, STA)：无线移动终端设备，它的接口符合无线媒体的 MAC 和 PHY 接口标准。

(3) 认证服务单元 (Authentication Service Unit, ASU)：它的基本功能是实现 STA 用户证书的管理和 STA 用户身份的认证等。ASU 作为可信任和具有权威性的第三方，保证公钥体系中证书的合法性。

1. WAPI 认证

WAPI 认证原理如图 11-20 所示。STA 与 AP 上都安装由 ASU 发放的公钥证书，作为自己的数字身份凭证。AP 提供 STA 访问 LAN 的受控端口和非受控端口的服务。STA 首先通过 AP 提供的非受控端口连接到 ASU 发送认证信息，只有通过认证的 STA 才能使用 AP 提供的数据端口 (即受控端口) 访问网络。

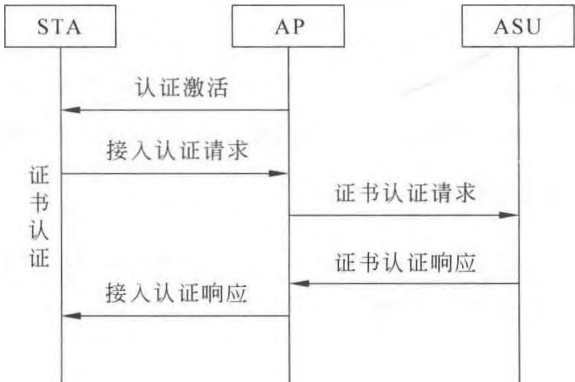


图 11-20 WAPI 认证原理

WAPI 认证过程如下：

(1) 认证激活。当 STA 关联或重新关联至 AP 时，由 AP 发送认证激活以启动整个

认证过程。

(2) 接入认证请求。STA 向 AP 发出认证请求，即将 STA 证书与 STA 当前的系统时间发往 AP，其中，系统时间称为接入认证请求时间。

(3) 证书认证请求。AP 收到 STA 接入认证请求后，首先记录接入认证请求时间，然后向 ASU 发出证书认证请求，即将 STA 证书、接入认证请求时间、AP 证书及 AP 私钥对它们的签名构成证书认证请求发送给 ASU。

(4) 证书认证响应。ASU 收到 AP 的证书认证请求后，验证 AP 的签名和 AP 证书的有效性，若不正确，则认证过程失败；若正确，则进一步验证 STA 证书。验证完毕后，ASU 将 STA 证书认证结果（包括 STA 证书和认证结果）、AP 证书认证结果（包括 AP 证书、认证结果、接入认证请求时间）和 ASU 对它们的签名构成证书认证响应报文发回给 AP。

(5) 接入认证响应。AP 对 ASU 返回的证书认证响应进行签名验证，得到 STA 证书的认证结果，根据此结果对 STA 进行接入控制。AP 将收到的证书认证结果回送至 STA。STA 验证 ASU 的签名后，得到 AP 证书的认证结果，根据认证结果决定是否接入该 AP。

至此，STA 与 AP 之间便完成了证书认证过程。若认证成功，则 AP 允许 STA 接入；若认证失败，则解除其关联。

2. WAPI 密钥协商与数据加密

STA 与 AP 认证成功后进行密钥协商的过程如下：

(1) 密钥协商请求。AP 产生一串随机数据，利用 STA 的公钥加密后，向 STA 发出密钥协商请求。此请求包含请求方所有的备选会话算法信息。

(2) 密钥协商响应。STA 收到 AP 发送来的密钥协商请求后，首先进行会话算法协商：若 STA 不支持 AP 所有备选会话算法，则向 AP 响应会话算法失败；否则，STA 在 AP 提供的会话算法中选择一种自己支持的算法。STA 利用本地私钥解密协商数据，得到 AP 产生的随机数，然后产生一个新的随机数，STA 利用 AP 的公钥对此随机数加密后，再发送给 AP。

密钥协商成功后，STA 与 AP 将自己与对方产生的随机数据进行“模 2 加”运算生成会话密钥，利用协商的会话算法对数据进行加/解密。为了进一步提高通信的保密性，通信一段时间和交换一定数量的数据之后，STA 与 AP 之间将重新进行会话密钥的协商。

11.3.6 WAP 的安全性

WAP 被广泛用于无线设备访问因特网，因为它是针对小显示屏和有限带宽的手持设备而设计的。本节讨论 WAP 的安全性。

1. WAP 网络架构

如图 11-21 所示，WAP (Wireless Application Protocol) 网络架构由 3 部分组成：WAP 设备、WAP 网关和 Web 服务器。

最早的 WAP 设备是多功能手机，除了提供传统的语音功能外，这种设备还包括一个 WAP 浏览器。后来，PDA 和 Pocket PC 上也提供了 WAP 浏览器功能。这些设备要么

用无线 Modem，要么用无线电话的红外线端口连接到无线网络上。WAP 浏览器负责从 WAP 网关上请求页面并将返回数据显示在设备上。它能解释 WML 的数据，也可以执行用 WMLScript 编写的程序。但是由于设备性能的局限性，WMLScript 程序通常在 WAP 网关上执行，然后再将结果返回到 WAP 设备。



图 11-21 WAP 网络架构

所有来自 WAP 设备的请求和数据都必须通过 WAP 网关转发到 Internet 上。WAP 网关的作用如下：

- (1) 协议转换。将无线数据协议（WDP）和无线传输层安全（WTLS）协议转换为有线网络协议如 TCP 或 TLS。
- (2) 内容转换。将 HTML 网页转换成 WML 兼容格式。
- (3) 性能优化。压缩数据，减少与 WAP 设备的交互次数。

当 WAP 网关收到 WAP 设备的请求后，会将它转换成 HTTP 格式并从 Web 服务器上获得页面。

2. WAP 安全架构

协议 WAP 的安全架构建立在无线传输层安全（WTLS）协议之上。

WTLS 协议是 WAP 采用的安全协议。它作用在传输层协议上，为 WAP 的高层协议提供安全传输服务接口。该接口保留了下面的传输层，并提供管理安全连接的机制。WTLS 的主要目的是给 WAP 应用提供机密性、数据完整性和认证服务。

WTLS 协议支持一系列算法。目前，保密性由分组加密算法（如 DES-CBC、IDEA 和 RC5-CBC）来实现；通信双方的认证通过 RSA 或 Diffie-Hellman 密钥交换算法来实现；而数据完整性由 SHA-1 或 MD-5 算法来实现。

WTLS 协议提供如下 3 类安全服务：

- (1) 第一类：匿名认证。客户端登录到服务器，但是客户端和服务器都无法确认彼此的身份。
- (2) 第二类：服务器认证。只有客户端确认服务器的身份，服务器不确认客户端的身份。
- (3) 第三类：双向认证。客户端和服务器彼此确认身份。

WTLS 协议是基于 TLS 协议开发出来的，但针对无线网络环境对 TLS 做了一些改变。首先，针对低延迟、低带宽的网络，WTLS 对 TLS 进行了优化。由于移动设备的处理能力和内存有限，WTLS 的算法族中采用了高效和快速的算法。其次，根据法律规定，必须遵守加密算法出口和使用的限制，所以在算法的选择上留有余地。虽然第三类服务提供了使用无线公钥基础设施（WPKI）的可能，但也带来了全新的问题，如用户的公钥/

私钥对应该如何管理等。虽然密钥可以存储在 SIM 卡内，但是网络运营商需要对已经发放的 SIM 卡进行升级，这无疑会带来巨大的工作量。针对这个问题，WAP 论坛开发出了无线身份识别模块（WIM），它可以是虚拟的，即将身份信息存储到 SIM 卡中未用的存储空间内或存储在单独的卡上。目前，WAP 的应用大多采用第一类或第二类认证。第二类认证的认证过程如下：

- （1）WAP 设备向 WAP 网关发送请求。
- （2）网关将自己的证书（包含网关的公钥）发回 WAP 设备。
- （3）WAP 设备取出证书和公钥，生成一个随机数，并用网关的公钥进行加密。
- （4）WAP 网关收到密文并用私钥解密。

该过程虽然简单，但是它通过最少的交互在用户和网关之间建立加密隧道。不幸的是，WTLS 协议只对从 WAP 设备到 WAP 网关之间的数据进行加密，从 WAP 网关到 Web 服务器之间的数据则采用 SSL 协议加密。由于数据必须由 WTLS 格式转换成 SSL 格式，所以在一段时间内 WAP 网关上的数据以明文形式存在，这会带来安全问题。

WAP 也提供了一个使用 WMLScript 编写的 WAP 设备数字签名程序 SignText，该程序提供防抵赖服务。

3. 基于 WAP 网关的端到端安全

WAP 采用 WTLS 建立了两个 WAP 端点——WAP 设备和 WAP 网关之间端到端的安全连接。当 WAP 网关将请求转发给 Web 服务器时，系统使用 SSL 协议来保障安全性。这就意味着数据将在 WAP 网关上解密和加密。在提供 WTLS 到 SSL 转换的同时，WAP 网关还需对网页上的小程序和脚本进行编译，因为大部分的 WAP 设备都没有配备编译器。值得注意的是，在从 WTLS 转换到 SSL 的过程中，数据在 WAP 网关上是以明文形式存在的，因此如果 WAP 网关没有妥善保护，数据的安全就会受到威胁。

为了弥补这一缺陷，WAP 提出了两点改进：第一，采用客户端应用代理将认证和授权信息传输给无线网络的服务器；第二，将数据在应用层加密，这样就保证了数据在整个传输过程中是加密的。

但是，WAP 网关最安全的应用方式还是把 WAP 网关设置在服务提供商的网络上，这样，客户端和服务提供商之间的连接就是可信的，因为解密过程是在服务提供商自己的网络上而不是在网络运营商的网络上进行的。

4. WTLS 记录协议

WTLS 记录协议从高层协议上获取原始数据，并对数据进行有选择的加密和压缩。记录协议负责保障数据的完整性和认证性。接收到的数据经过解密、验证和解压传输到上层协议。记录协议通过一个 3 步握手机制建立安全通信：首先，握手协议开始建立一个连接；其次，改变加密细节协议就通信双方采用的加密算法细节达成一致；最后，报警协议报告错误信息。这 3 个协议的工作内容如下：

- （1）握手协议。所有的安全参数都在握手中确定。这些参数包括协议版本号、加密算法及采用认证和公钥技术生成的共享密钥等信息。
- （2）改变加密细节协议。改变加密算法细节的请求可以由服务器或客户端发起，当

收到请求后,发送者会由写状态转为挂起状态,而接收者也由读状态转为挂起状态。

(3) 告警协议。有 3 种告警信息——警告、紧急和致命错误。告警信息可以采用加密和压缩方式传输,也可以采用明文方式传输。

11.4 Ad hoc 网络的安全性

自组织网络 (Ad hoc Network) 是由一组带有无线网络接口的移动终端在没有固定网络设施辅助和集中管理的情况下搭建的临时性网络。当两个移动终端在彼此的通信覆盖范围内时,它们可以直接通信。由于移动终端的通信覆盖范围有限,如果两个相距较远的主机要进行通信,则需要通过它们之间的移动终端转发才能实现。因此,在 Ad hoc 网络中,主机同时还是路由器,担负着寻找路由和转发报文的工作。每个主机的通信范围有限,因此路由一般都由多跳组成,数据通过多个主机的转发才能到达目的地,故 Ad hoc 网络也被称为多跳无线网络。

Ad hoc 网络拓扑结构图如图 11-22 所示。

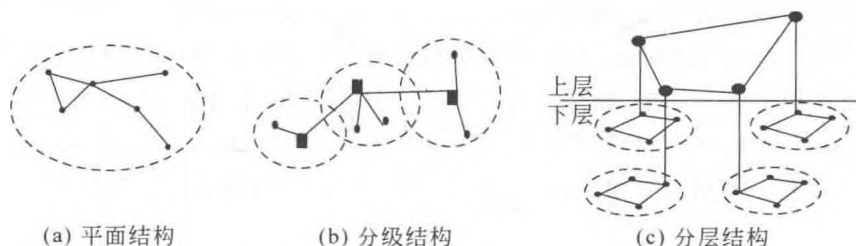


图 11-22 Ad hoc 网络拓扑结构图

Ad hoc 网络的应用范围很广,它适用于以下场合:

- (1) 没有有线通信设施的地方,如没有建立硬件通信设施或有线通信设施遭受破坏。
- (2) 需要分布式特性的网络通信环境。
- (3) 现有有线通信设施不足,需要临时快速建立一个通信网络的环境。
- (4) 作为生存性较强的后备网络。

Ad hoc 网络具有自组织性、无中心性、动态拓扑、资源受限和多跳路由的特点。这些特性也带来了其安全的特殊性,如下所述:

- (1) Ad hoc 网络采用无线信号作为传输媒介,很容易被窃听和干扰。

(2) 网络节点是自主移动的,节点的安全性十分脆弱。例如在战场上,节点随时可能落入敌人之手,节点内的密钥、报文信息等存在被破获的风险,被攻破的节点随后又可能以合法用户身份加入网络。因此,Ad hoc 不仅要防范来自外部的入侵,还要防御来自内部节点的攻击。

(3) Ad hoc 网络中节点位置随时改变,造成网络拓扑的不断变化,因此造成路由途径的不断变化。我们很难判断一条错误的路由是因节点的移动所致还是因虚假路由信息所形成。由于节点的移动性,在某处被发现攻击者可能移动到新的地点,通过改变标

识重新加入网络。另外，由于 Ad hoc 网络的动态网络拓扑特性，它不存在网络边界的概念，Internet 中常用的防火墙等安全设备也无法在 Ad hoc 网络中应用。

(4) 在传统的非对称密钥体制中，用户常采用加密、数字签名、消息认证码 MAC 等技术来实现信息的机密性、完整性、不可抵赖性等安全服务，它需要一个可信任的认证中心 CA 来提供密钥管理服务。但在 Ad hoc 网络中不允许存在认证中心，因为认证中心的崩溃将造成整个网络无法获得认证，即单点失败。更严重的是，被攻破的认证中心的私钥可能会泄漏给攻击者，攻击者可以使用该私钥来签发伪造的证书，假冒网络中任意一个移动节点或废除所有合法的证书，致使整个网络完全失去安全性。

(5) 目前的路由算法都假定网络中所有节点是相互合作的、可信的，它们相互配合以完成网络信息的传递。如果网络中某些自私节点为节省本身的资源而停止转发数据，就会影响整个网络的性能。如果参与到网络中的攻击者专门广播虚假的路由信息或故意广播大量的无用数据包，可能导致整个网络的崩溃。

(6) Ad hoc 网络终端资源受限，在制定和实施安全方案时，必须充分考虑其计算量和通信量等。

不难看出，Ad hoc 网络的安全问题比传统网络突出，解决起来难度更大。传统网络中存在的安全问题在 Ad hoc 网络中同样存在，而且由于其特殊性，Ad hoc 网络又面临新的安全威胁，如针对 Ad hoc 网络的女巫攻击等。目前在传统网络中大量使用的安全解决方案，包括防火墙、VPN 及 IDS 等，不能直接应用于 Ad hoc 网络。

目前，Ad hoc 网络安全领域研究热点集中在以下几个方面：①Ad hoc 网络保密与认证技术；②Ad hoc 网络安全路由；③Ad hoc 网络入侵检测技术；④Ad hoc 网络信任建立与度量。

11.4.1 Ad hoc 网络保密与认证技术

保密与认证技术用来认证合法的节点、加密传输信息、减小敌人发动攻击成功的可能性，是 Ad hoc 网络安全的第一道屏障。现有的 Ad hoc 网络保密与认证方案可以分为双钥体制方案（非对称密码体制）和单钥体制（对称密码体制）方案。双钥体制方案主要用于移动 Ad hoc 网络（Mobile Ad hoc Networks, MANET）中，而单钥体制方案主要用于无线传感器网络（Wireless Sensor Network, WSN）中。

1. 双钥体制方案

在双钥体制方案中，最典型的是分布式 CA 密钥管理与认证方案。分布式 CA 方案分为部分分布式 CA 方案和完全分布式 CA 方案两种情况。

部分分布式 CA 方案的基本思想是利用 (n, t) 门限密钥共享体制把 CA 中心分散到 n 个服务器中。系统有一个公钥/私钥对 K/k 。公钥 K 对网络中的所有节点公开，而私钥 k 被分成了 n 个份额 $s_1, s_2, \dots, s_n$ ，每个服务器 i 有一个份额，如图 11-23 所示。在 (n, t) 门限签名体制中，用系统私钥 k 产生一个签名，至少需要 n 个服务器中的 t 个服务器合并它们的私钥份额。对于一个消息 m ，服务器 i 用自己的私钥份额 s_i 生成一个对 m 的签名分量 $PS(s_i, m)$ ； n 个服务器中的 t 个服务器产生自己的签名分量，并将它发送给组合节

点 C ; C 用这 t 个签名分量生成系统对 m 的签名, 而不会泄漏整个系统的私钥 k 。少于 t 个服务器的签名分量不能合作产生系统对消息 m 的签名。同时, 合并节点可以用系统公钥 K 验证签名的正确性。图 11-24 说明了服务器是如何采用门限签名方案产生一个系统签名的。后来的改进方案取消了组合节点 C , 提高了系统的效率和可用性。这种方案考虑了 Ad hoc 网络的特点, 有效地防止了单点失败, 具有很好的抗毁性。

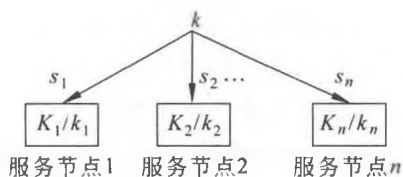


图 11-23 密钥管理服务配置

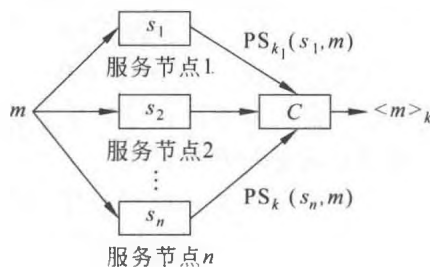


图 11-24 门限签名方案

完全分布式 CA 方案扩展了部分分布式 CA 方案, 取消了特殊的 CA 节点, CA 中心的任务由所有的网络节点共同承担, 每个节点都持有一份私钥份额, 任意 t 个节点联合可以完成加/解密和证书操作, 符合 Ad hoc 网络节点地位平等的特点。此类方案充分利用邻接节点具有较好的网络连接性和易于监控的特点, 使证书服务既分散化又本地化, 能较好地适应动态的网络拓扑结构。

(1) 自组织密钥管理方案。基于 PGP (Pretty Good Privacy) 的思想, 不需要由 CA 颁发证书, 而是节点相互颁发并维护证书。每个用户都能在本地维护一个证书库。当两个用户需要相互认证时, 它们合并各自拥有的证书库, 形成一张认证路径图, 并从该图中寻找一条认证路径。认证成功取决于用户的本地证书库构成方式和认证路径图的特性。这种方案实现了完全的自组织, 而且建立阶段比较简单。

(2) 基于身份的密钥管理与认证方案。将基于身份的密码机制与分布式 CA 方案的思想相结合。基于身份的密码机制使用节点身份标识, 如姓名、邮件地址等, 作为公钥, 这主要有两个优势: ①不需要公钥证书; ②不需要交换公钥。方案中由一组选定的节点共同承担密钥分发中心 (Key Distributed Center, KDC) 的职责, 它们根据 (n, t) 门限方案获得系统私钥的一个份额, 联合为节点产生私钥。

基于杂凑链 (Hash Chain) 认证的基本思想是: 一个杂凑函数 h 对随机数 x 应用 n 次, $x_n = h^n(x)$ 是杂凑链的最后一个值。每个设备计算自己的杂凑链, 在认证的方式下和通信伙伴交换 x_n , 保证 x 不泄漏。一个被杂凑链中 x_i 询问的设备通过应答杂凑链中的前一个值 x_{i-1} 来证明自己的身份, 只有知道 x 的设备才能计算要求的应答。这种杂凑链机制也称为密钥链, 它只提供单向认证, 且在协议执行中没有建立密钥。基于这种方法提出的认证协议很多, 比较有代表性的是 TESLA (Timed Efficient Stream Loss-tolerant Authentication)。在 TESLA 中, 发送者首先利用数字签名将 x_n 发送到另一方, 发送数据包 P_i 时, 利用杂凑链中的一个值 x_j 作为密钥, 计算发送数据 m 的消息认证码 $MAC(m, x_j)$, 随同消息一起发送, 在下一个数据包 P_{i+1} 中公布 x_j , 并利用 x_{j-1} 做上述操作。接收者在收到 P_{i+1} 后, 首先利用 x_{j+1} 来验证 x_j 的正确性, 即验证发送者身份的正确性, 然后用 x_j 验

证数据包 P_i 的真实性。

2. 单钥体制方案

单钥体制方案比较多，这里仅介绍比较典型的几类方案。

（1）基于密钥池的密钥预分发方案。

最基本的基于密钥池的密钥预分发方案（简称 E-G 方案）由 3 个阶段组成。第 1 阶段为密钥预分发阶段。服务器首先生成一个密钥总数为 P 的大密钥池及密钥标识，每一节点从密钥池里随机选取 k ($k \ll P$) 个不同的密钥。这种随机预分发方式使得任意两个节点能够以一定的概率存在着共享密钥。第 2 阶段为共享密钥发现阶段。随机部署后，两个相邻节点若存在共享密钥，就随机选取其中的一个作为双方的配对密钥，否则进入第 3 阶段。第 3 阶段为密钥路径建立阶段，节点通过与其他存在共享密钥的邻居节点经过若干跳后建立双方的一条密钥路径。E-G 方案在以下 3 个方面满足和符合 WSN 的特点：一是节点仅存储少量密钥就可以使网络获得较高的安全连通概率；二是密钥预分发时不需要节点的任何先验信息（如节点的位置信息、连通关系等）；三是部署后节点间的密钥协商无须服务器的参与，使得密钥管理具有良好的分布特性。

q-composite 随机密钥预分发方案（q-composite Random Key Pre-distribution Scheme）是对 E-G 方案的改进。节点从密钥总数为 P 的密钥池里预随机选取 k 个不同的密钥，部署后两个相邻节点至少需要共享 q 个密钥才能直接建立配对密钥。随着 q 值的增大，攻击者能够破坏安全链路的难度呈指数增加，但同时节点的存储空间需求也增大。

（2）基于密钥矩阵的动态密钥产生方案。

此方案利用一个有限域 Z_q^* 上的 $(\lambda+1) \times N$ 的公共矩阵 G 和一个 $(\lambda+1)(\lambda+1)$ 的秘密矩阵 D 为网络中的各个节点生成动态密钥，其中 N 为网络中节点数量。密钥矩阵被定义为对称矩阵 $K = (D \cdot G)^T \cdot G$ 。节点 S_i 存储矩阵 G 中的第 i 列 column_i 作为公共信息，存储矩阵 $(D \cdot G)^T$ 中的第 i 行 row_i 作为私有信息。当两个节点 (S_i, S_j) 协商密钥时，首先交换公共信息 column_i 和 column_j ，然后分别计算密钥 $K_{ij} = \text{row}_i \times \text{column}_j$ 和 $K_{ji} = \text{row}_j \times \text{column}_i$ ，如图 11-25 所示。

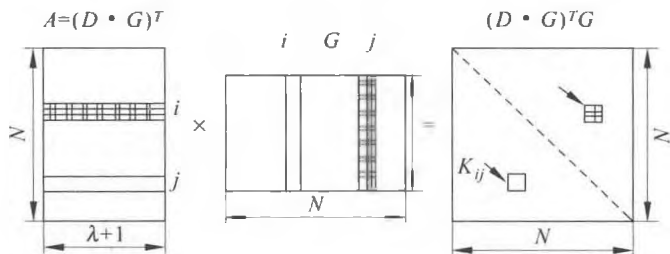


图 11-25 基于密钥矩阵的动态密钥产生方案

（3）基于多项式的动态密钥产生方案。

采用类似于密钥矩阵的对称密钥思想：对于一个 $2t$ 次的二元多项式 $f(x, y) = \sum_{i,j=0}^t a_{ij} x^i y^j$ ，具有 $f(x, y) = f(y, x)$ 性质。节点上预先存储 $f(x, i)$ ， i 为节点标识。一个网络节点仅需要邻居节点的标识 j ，即可独立计算 $f(i, j) = f(j, i)$ 。该方式所需的计算量

大，当网络规模增大时可用性不强。

(4) 基于部署知识 (Deployment Knowledge) 的密钥管理方案。

基于部署知识的密钥预分发是一种辅助方案，可以与其他密钥方案相结合，达到优化密钥的预分发方案性能的目的。该方案的基本思路是：使网络中近距离节点大概率直接连通，远距离节点小概率直接连通，甚至零概率连通。以基于密钥池的方案为例，假定网络的部署目标区域是一个二维矩形区域， n 个节点被分成 g 个相等的组，每个组有 n/g 个节点，如图 11-26 所示。密钥池（密钥数为 $|S|$ ）被划分成若干个子密钥池（密钥数为 $|S_c|$ ），每个子密钥池对应于一个部署组。若两个子密钥池是水平或垂直相邻，则至少共享 $a|S_c|$ 个密钥；若两个子密钥池是对角相邻，则至少共享 $b|S_c|$ 个密钥（ a, b 满足以下关系： $0 < a, b < 0.25$ 且 $4a+4b=1$ ），若两个子密钥池不相邻，则没有共享密钥，如图 11-27 所示。对于组内每一个节点，从对应的子密钥池随机取 m 个不同的密钥。部署后，若相邻节点存在共享密钥，则可以直接建立配对密钥。这种方法提高了节点的安全连通概率，在安全连通概率确定的条件下，可以减少节点存储密钥的数量，从而减少节点被俘时密钥的泄漏，最终提高网络的抗节点俘获能力。

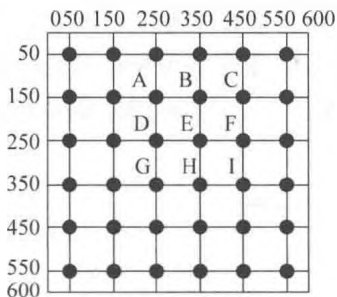


图 11-26 节点部署位置的划分

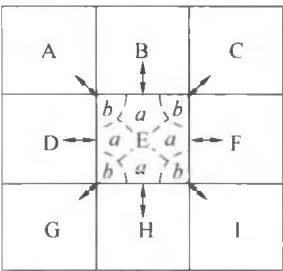


图 11-27 子密钥池的重叠关系

除了上述代表性方案外，还有基于组合理论的密钥分发方案、基于 EBS 的密钥分发方案、LEAP、SPINS、Pebblenets 和复活鸭子模型等。

11.4.2 Ad hoc 网络的安全路由

安全路由协议的目标是实现路由信息的可用性、真实性、完整性和抗抵赖性，防止恶意节点对路由协议的破坏。已有的路由协议（DSR、AODV、DSDV 等）均假设存在安全的网络环境，这些协议不能对抗针对路由的攻击。因此，研究者在这些协议的基础上，应用密码技术，提出了 SEAD、Ariadne、ARAN、SAODV 等安全路由协议。这些安全协议都需要一些先决条件，如节点在通信之前能够交换初始参数、协商会话密钥或有可信的第三方颁发的证书等。在协议执行的过程中，它们采用数字签名、杂凑链及信任机制来保证路由信息安全可靠。

11.4.3 Ad hoc 网络的入侵检测

在移动环境中，并不能很明确地区分正常行为和异常行为，所以传统网络中的 IDS 技术不能直接应用到 MANET 中。针对 MANET 的特点，国际国内出现了多种入侵检测

系统模型，使用不同的方法集中或分散 IDS 的监测任务，分布式地监视网络状况，共享信息，合作检测入侵行为。近来人们提出的方案有：①基于代理的分布式协作入侵检测方案；②动态协作的入侵检测方案；③基于时间自动机的入侵检测算法；④基于区域划分的入侵检测方案；⑤基于人工免疫的入侵检测方案等。

11.4.4 Ad hoc 网络的信任建立

信任可分为身份信任和行为信任。身份信任是基于证书或标识的对实体身份的信任，行为信任是基于实体行为和信誉的对实体能力、可靠性等属性的信任。身份信任确保行为信任评估的安全性、准确性，是后续安全机制实施的基础；行为信任为身份信任关系的安全建立、更新及撤销提供保障。身份信任主要靠认证技术来实现，但现有的身份信任模型还存在很多不完善的地方。例如，不能很好地解决新加入的网络节点与其他节点建立身份信任关系的问题，证书撤销的决策缺乏信任依据，等等。另外，仅实现网络节点间的身份信任也无法完全解决 Ad hoc 网络中的路由安全问题。例如，黑洞攻击和网络中的自私行为等问题仍然存在。行为信任评估本质上就是通过收集和處理实体行为的证据信息获得经验，并以此为依据做出信任决策，这是行为信任的核心。目前，行为信任技术包括可信计算技术和信任度量模型建立。现有行为信任评估模型中普遍没有身份信任和通信保密性的保障，很难实现安全、准确的信任评估。Ad hoc 网络的信任问题还需要进一步研究。

习 题

一、填空题

1. 无线网络面临的安全威胁主要有_____、_____、_____、_____和_____（请写出 5 种）。
2. GSM 网络由_____、_____、_____、_____、_____、_____和_____8 部分构成。
3. 3G 网络中接入链路数据保护方式有两种：_____和_____。
4. 802.11i 中有_____和_____两种加密模式。
5. 802.1x 系统中有_____、_____和_____3 个角色。
6. 802.16 的安全子层由_____、_____、_____、_____和_____5 部分组成。
7. WAPI 安全机制由_____和_____两部分组成。整个系统由_____、_____和_____组成。
8. Ad hoc 网络的特点有：_____、_____、_____、_____和_____。拓扑结构有_____、_____和_____3 种。

二、简答题

1. 无线网络技术可以分为哪两大类？这两大类中的代表分别是什么？

2. 无线局域网采用哪两种扩谱技术？
3. GSM 网络的体系结构是怎样的？简要描述 GSM 网络的认证过程。
4. 3G 网络的安全性由哪几部分保证？
5. 简要描述 CDMA 网络的认证过程。
6. 简要描述 WEP 的加/解密过程。
7. 802.11i 由哪几部分组成？各部分的层次是怎样的？
8. 802.11i 中采用的 TKIP 针对 WEP 做了哪些改进？
9. 802.11i 中两种加密模式的区别是什么？
10. 802.16 的安全子层由哪几部分组成？各部分的作用是怎样的？
11. 802.1x 系统中有哪 3 个角色，这些角色是如何相互作用的？
12. WAPI 安全机制中每部分的作用是什么？简述具体过程。
13. Ad hoc 网络的保密与认证技术都有哪些？
14. 无线网络面临的安全威胁主要包含哪几种？如何预防这些威胁？